

Kit d'exercice de crise SI fictive (scénario 48 h)

Un exercice sur table pour tester les décisions du comité, pas les systèmes

L'objectif n'est pas de tester vos systèmes mais vos décisions et votre organisation. Si votre équipe de direction ne peut pas répondre avec fluidité à ces questions lors d'un exercice tranquille, elle ne pourra pas y répondre sous pression lors d'une vraie attaque. Format conseillé : 90 minutes sur table, une fois par an, avec le comité de direction.

1. Le scénario

Lundi, 7h42. Les postes affichent un message de rançon, des serveurs de fichiers sont chiffrés, une application critique est inaccessible. On ignore encore l'ampleur réelle et le vecteur d'entrée. Déroulez le scénario sur 48 heures simulées, en introduisant de nouvelles informations toutes les 15 minutes.

2. La cellule de crise et les rôles

Le dirigeant tient le rôle du commandant de bord, pas du mécanicien. Réunissez autour de la table : direction générale, responsable de la sécurité (RSSI), direction informatique, communication, juridique / conformité, et un représentant métier des processus critiques. Désignez explicitement qui décide quoi.

3. Les questions de décision à traiter

- ? Qui appelle-t-on en premier, et qui active la cellule de crise ?
- ? Qui a l'autorité pour décider d'isoler un système de production, même si cela arrête l'activité ?
- ? Que disons-nous aux collaborateurs, et par quel canal, dès la première heure ?
- ? Comment communique-t-on avec les clients dont les données pourraient être compromises ?
- ? Qui notifie les autorités compétentes, et dans quels délais ?
- ? Qui appelle l'assureur cyber, et qu'attend-on concrètement de cet appel ?
- ? Nos sauvegardes hors ligne sont-elles intactes, et la restauration a-t-elle déjà été testée ?

4. Les cinq communications à préparer

Partie prenante	Message essentiel	Pourquoi
Collaborateurs	Ce qui se passe et comment travailler en mode dégradé.	Ils l'apprendront de toute façon ; le silence nourrit la rumeur.
Clients	Si leurs données sont compromises et quand les services seront rétablis.	Question non négociable : ils peuvent l'imposer en quelques heures par les réseaux sociaux.
Partenaires et prestataires	S'il existe un risque de propagation depuis votre réseau vers le leur.	Demande légitime à anticiper.
Autorités	Notifications selon la nature de l'incident.	Délais imposés par la loi : à préparer à froid.
Médias	Un message maîtrisé plutôt qu'un message subi.	Ils s'empareront du sujet si l'incident est significatif.

5. Le débriefing

À chaud, listez les décisions qui ont hésité, les rôles mal définis et les informations qui ont manqué. Transformez ces constats en un court plan d'action daté. La valeur de l'exercice est dans les écarts qu'il

révèle, pas dans son bon déroulement apparent.

Référence dans le livre

Ce kit étend l'action à 30 jours du chapitre 1 et mobilise le chapitre 12, « Résilience, cybersécurité et continuité d'activité ».
Page à préciser à la parution.

L'auteur s'exprime à titre personnel. © 2026 Mehdi Moudden.